

CVE-2023-51764

This document explains the CVE-2023-51764 as a Postfix SMTP Smuggling vulnerability. The main issue is that two mail servers interpret the end of the same SMTP data differently. The first server may see the data as one email while the second Postfix server may interpret it as two separate emails. Timo Longin hypothesized that if a non-standard but similar false terminator were sent, the two servers might interpret it differently.

🚩 CVE-2023-51764 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Current Description

Postfix through 3.8.5 allows SMTP smuggling unless configured with `smtpd_data_restrictions=reject_unauth_pipelining` and `smtpd_discard_ehlo_keywords=chunking` (or certain other options that exist in recent versions). Remote attackers can use a published exploitation technique to inject e-mail messages with a spoofed MAIL FROM address, allowing bypass of an SPF protection mechanism. This occurs because Postfix supports <LF>, <CR><LF> but some other popular e-mail servers do not. To prevent attack variants (by always disallowing <LF> without <CR>), a different solution is required, such as the `smtpd_forbid_bare_newline=yes` option with a Postfix minimum version of 3.5.23, 3.6.13, 3.7.9, 3.8.4, or 3.9.

[+View Analysis Description](#)

Metrics

CVSS Version 4.0 CVSS Version 3.x CVSS Version 2.0

NVD enrichment efforts reference publicly available information to associate vector strings. CVSS information contributed by other sources is also displayed.

CVSS 3.x Severity and Vector Strings:



NIST: NVD

Base Score: **5.3 MEDIUM**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

QUICK INFO

CVE Dictionary Entry:

[CVE-2023-51764](#)

NVD Published Date:

12/24/2023

NVD Last Modified:

06/17/2026

Source:

MITRE

CVE-2023-51764

 **Common Weakness Enumeration**
A community-developed list of SWP & HW weaknesses that can become vulnerabilities

for **25** **HW** **CWE**

New to CWE?
[Start here!](#)

Home > CWE List > CWE-345: Insufficient Verification of Data Authenticity (4.20)

Home | About | Learn | Access Content | Community | Search

CWE-345: Insufficient Verification of Data Authenticity

Weakness ID: 345
Vulnerability Mapping: **DISCOURAGED**
Abstraction: Class

View customized information:

Description

The product does not sufficiently verify the origin or authenticity of data, in a way that causes it to accept invalid data.

Common Consequences

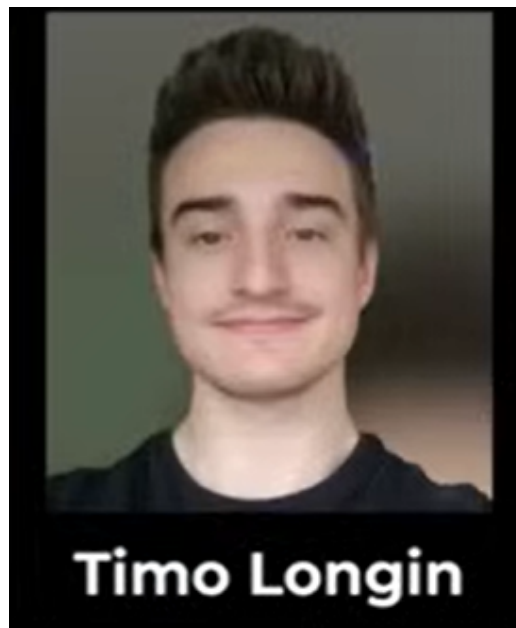
Impact

Details

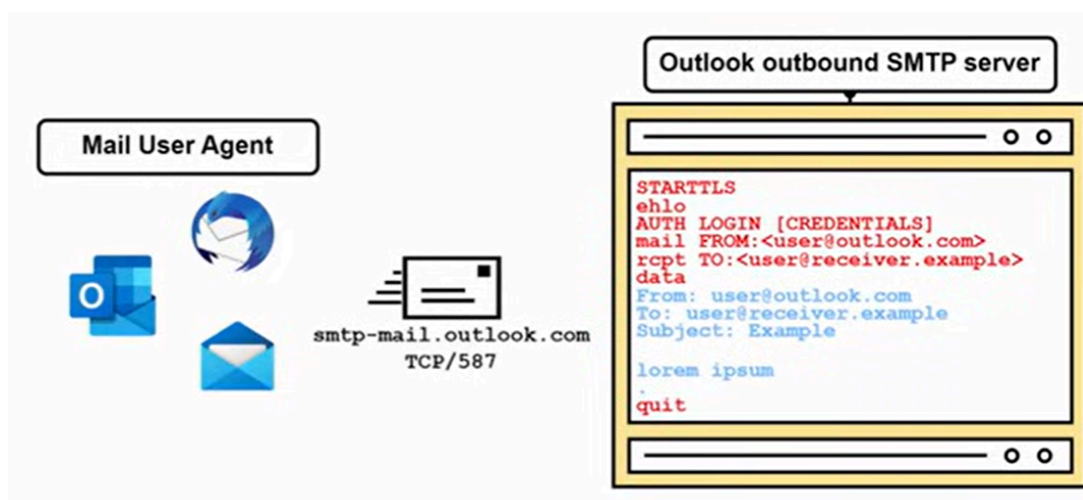
Varies by Context: Unexpected State

Scope: Integrity, Other

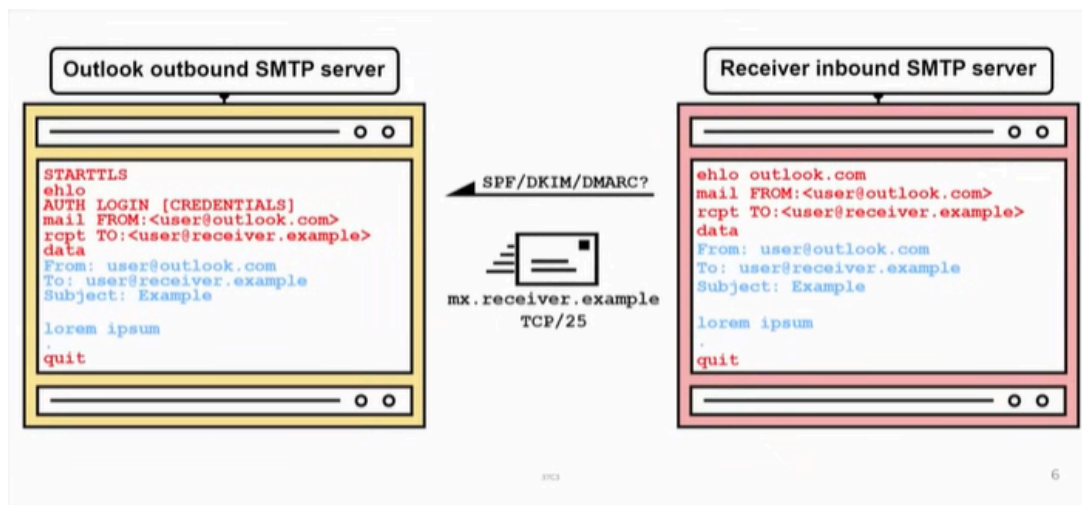
CWE-345



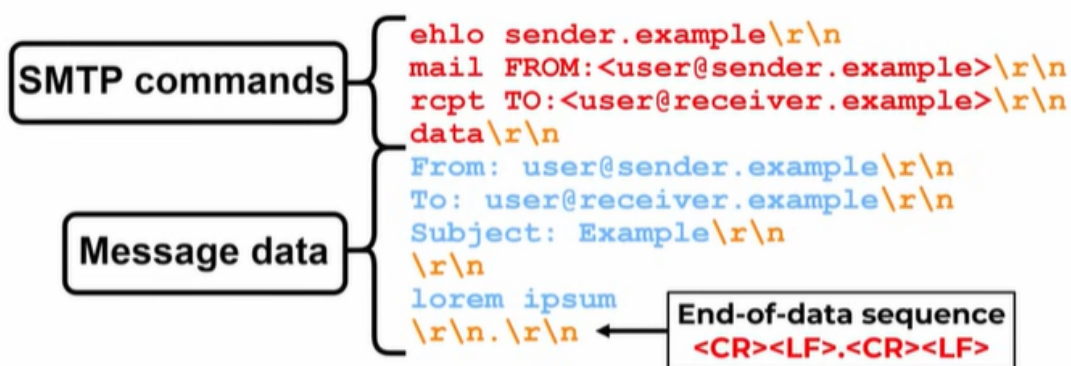
Timo Longin, a security researcher at SEC Consult, discovered the SMTP smuggling vulnerability affecting Postfix in June 2023.



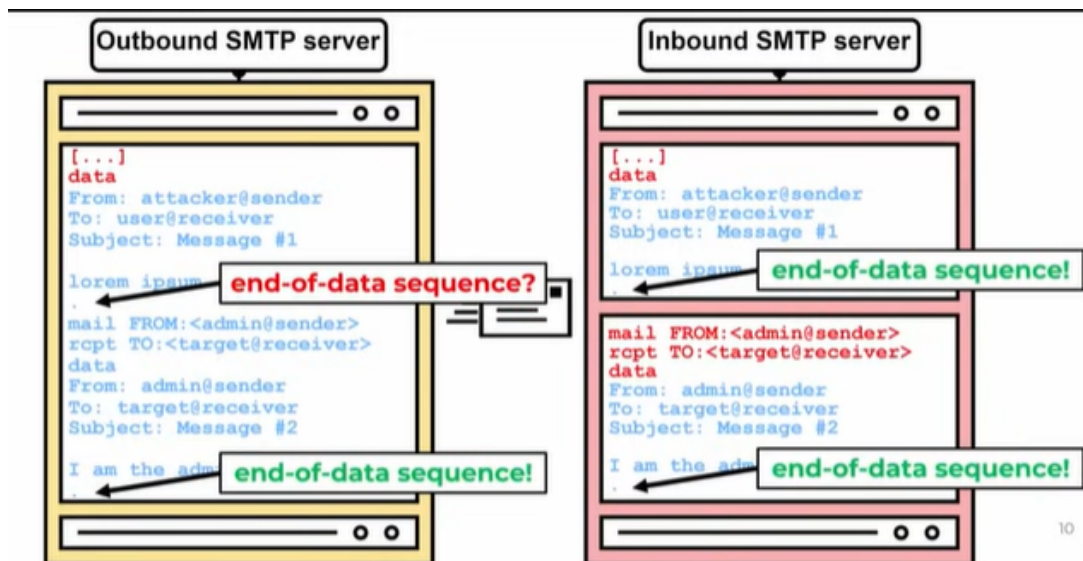
On the left, there is a Mail User Agent (MUA). This is the application used by the user, such as Outlook, Thunderbird, another email application. When the user writes and sends an email, the application connects to the following server → smtp-mail[.]outlook[.]com (TCP/587) → Defanged. `smtp-mail.outlook.com` is Outlook's outbound SMTP server. Port `587` is the submission port used by authenticated users to send emails, sending to Outlook outbound SMTP server in this example. As shown in the right side, single dot indicates the end of the `DATA` section and `QUIT` terminates the SMTP session.



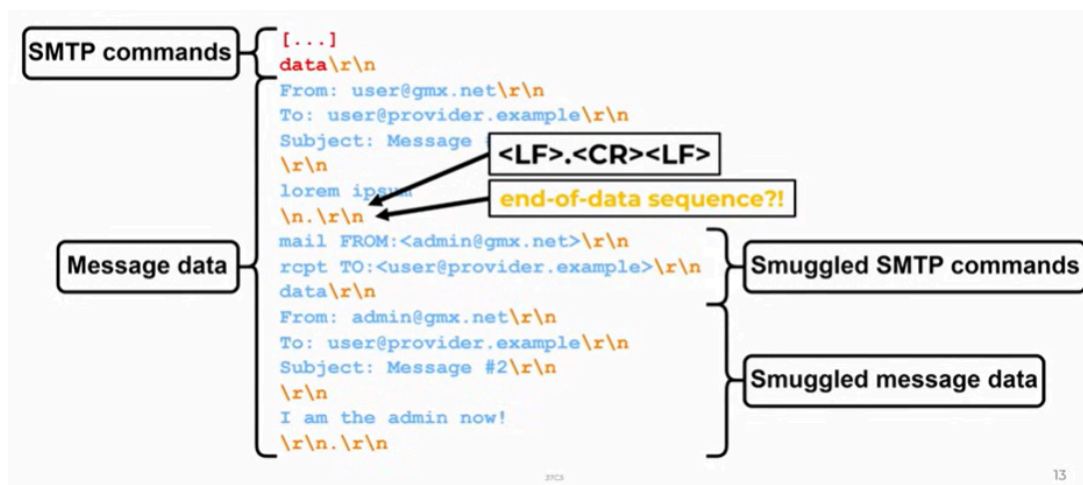
Outlook first queries DNS to find the MX record of the `receiver.example` domain. It then connects to the specified mail server over TCP port `25`. In this example, the recipient's server is shown as `mx[.]receiver[.]example` (TCP/25). `mx.receiver.example` is the inbound mail server of the recipient's domain. Port `25` is the SMTP port used by mail servers to transfer emails from one to another.



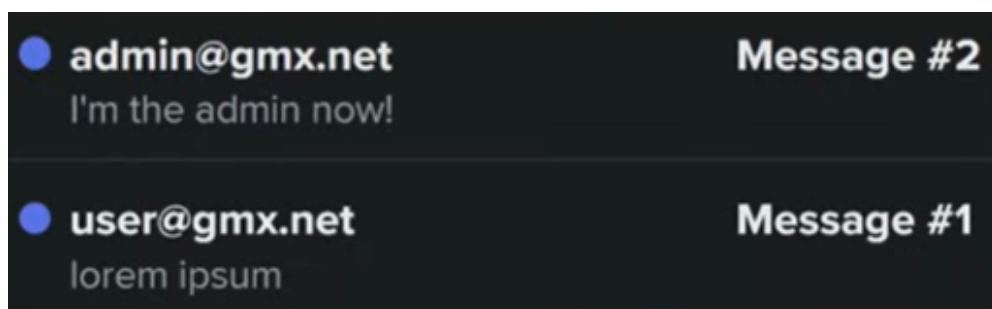
The main issue in SMTP Smuggling occurs precisely at the message-termination stage. One server recognizes only the standard `\r\n.\r\n` sequence as the end of an email, while another server may also accept a non-standard variant as a valid terminator.



This example shows how two different servers understand one big mail differently. The outbound server does not recognize the false terminator in the middle. Since it is not a standard terminator, the server interprets the email as still ongoing. The inbound server, however, interprets the non-standard terminator in the middle as a genuine End-of-Data marker and assumes that the first email ends at that point.



Example for smuggled SMTP commands and message data



This is the observation from Receiver's inbox.



Dot-Stuffing

If a line in the email body begins with a dot, the SMTP client adds an extra dot before it. Upon receiving the message, the server removes one of the dots. This is known as the “transparency” mechanism, and it prevents ordinary message content from being accidentally interpreted as the End-of-Data (EOD) marker.

In SMTP Smuggling, the problem arises when the dot-stuffing rule is combined with different interpretations of line-ending sequences.

Authentication-Results:

SPF compares the connection IP address observed by the receiving server with the DNS SPF policy of the domain specified in the SMTP envelope’s `MAIL FROM` command. Because the smuggled message reaches the recipient from the sender’s legitimate outbound IP address, the SPF check may return `pass` if that IP address is authorized in the spoofed domain’s SPF record. The attacker’s personal IP address is not directly visible to the recipient.

On the other hand, if the second hidden email does not contain a separate, valid DKIM signature, it will not pass DKIM verification.

DMARC requires alignment between the domain in the visible `From:` header and either the SPF-authenticated envelope domain or the DKIM `d=` domain. If the attacker configures the second `MAIL FROM` command and the visible `From:` field to use the same domain—a domain for which the sending server is authorized by SPF—DMARC may pass through the SPF authentication path.

The dangerous aspect of SMTP Smuggling is that the second email is generated within the connection established by a legitimate outbound server. Therefore, if SPF passes and the required alignment is satisfied, DMARC may also be bypassed. The attacker’s objective is not technically to “take control of the server” rather, the primary goal is to gain the recipient’s trust, deceive the user, and obtain money or account credentials.

Defense Mechanism

The strongest protection against SMTP Smuggling can be configuring the mail server so that the only valid indication of the end of an email is the conventional sequence.

Non-standard single LF line breaks should be normalized (or rejected altogether). Keeping Postfix updated and confirming the following parameter (in the effective configuration) is present

```
smtpdforbidbare_newline = normalize
```

or other approach can be:

```
smtpdforbidbare_newline = reject
```

Even, enabling restricted pipelining control can prevent unauthorized SMTP commands from being sent in rapid succession. This protection must be implemented not only on the primary mail server but on ALL primary MX, backup MX, gateway and relay systems in other case, one vulnerable system in the delivery path may allow the attack to succeed.

References

- <https://www.youtube.com/watch?v=V8KPV96g1To>
- [https://gchq.github.io/CyberChef/#recipe=Defang_URL\(true,true,true,'Valid domains and full URLs'\)&input=c210cC1tYWlsLm91dGxvb2suY29tCg](https://gchq.github.io/CyberChef/#recipe=Defang_URL(true,true,true,'Valid domains and full URLs')&input=c210cC1tYWlsLm91dGxvb2suY29tCg)
- <https://nvd.nist.gov/vuln/detail/cve-2023-51764>
- <https://cwe.mitre.org/data/definitions/345.html>
- <https://www.youtube.com/watch?v=TfX-XilgH0M>